POLÍTICA DE GESTIÓN DE RIESGOS

1. Alcance

El alcance de esta política abarca todos los sistemas, servicios y componentes tecnológicos que forman parte de la infraestructura de la organización, incluyendo hardware, software, entornos virtuales, dispositivos de red, servicios en la nube y cualquier plataforma que soporte la operación. Esta política aplica también a cualquier elemento cuyo funcionamiento dependa de firmware, con especial atención a las vulnerabilidades que requieran la aplicación de actualizaciones críticas para mantener la integridad, disponibilidad y seguridad del entorno.

La política es obligatoria para todas las áreas que intervienen en la gestión, operación y soporte de los activos tecnológicos. Incluye tanto a personal interno como a proveedores externos que administren sistemas o elementos que formen parte del inventario de activos. El alcance cubre el ciclo completo de identificación, evaluación y tratamiento de riesgos, así como la aplicación coordinada de controles preventivos y correctivos en alineación con los marcos de referencia utilizados por la organización.

Esta política se aplica a cualquier riesgo que pueda impactar la confidencialidad, integridad o disponibilidad de los sistemas, incluyendo riesgos asociados a vulnerabilidades de firmware, falta de actualizaciones críticas, fallas de control en la gestión de parches, incidentes derivados de la ausencia de monitoreo o controles adecuados, y cualquier debilidad que pueda comprometer la resiliencia de las plataformas tecnológicas.

2. Propósito de la Política de Gestión de Riesgos

El propósito de esta política es establecer un marco claro y consistente para identificar, evaluar y tratar los riesgos que afectan a los sistemas y activos tecnológicos de la organización. Su función principal es asegurar que exista un proceso formal que permita reducir el impacto de amenazas que puedan comprometer la operación, incluyendo aquellas derivadas de vulnerabilidades

críticas en firmware que requieren actualización inmediata para mantener la continuidad y seguridad del entorno.

La política busca orientar a todas las áreas involucradas en la gestión de activos para que adopten prácticas uniformes de análisis de riesgo, priorización, aplicación de controles preventivos y ejecución de acciones correctivas. Asimismo, define los criterios que permitirán determinar cuándo un riesgo debe ser escalado, mitigado o tratado mediante un proceso de Respuesta a Incidentes.

En conjunto, este documento establece la base que soporta la toma de decisiones informadas y oportunas, de modo que la organización pueda anticipar, contener y resolver riesgos tecnológicos antes de que se conviertan en incidentes que afecten la integridad, disponibilidad o confiabilidad de los servicios.

3. Marcos de referencia aplicables

Esta política se sustenta en prácticas reconocidas a nivel internacional para la gestión de riesgos, gestión de vulnerabilidades y respuesta a incidentes. Los siguientes marcos de referencia y lineamientos guían la manera en que se identifican amenazas, se priorizan actualizaciones críticas de firmware y se establecen controles preventivos y correctivos:

- **CISA Vulnerability Playbook**, como guía operativa para la identificación, priorización y tratamiento de vulnerabilidades que requieren acciones inmediatas.
- **NIST SP 800-61r3**, que establece el ciclo de vida de la respuesta a incidentes y define las bases para la detección, análisis, contención y recuperación.
- **NIST SP 800-40r4**, que proporciona el marco principal para la gestión de parches, incluyendo la evaluación de criticidad y la coordinación de actualizaciones de firmware.
- **ISO/IEC 27002**, específicamente los controles 8.8 y 12.6.1, como referencia para la gestión de vulnerabilidades y la aplicación controlada de actualizaciones.
- **CIS Controls 1, 3, 7 y 11**, que aportan directrices sobre inventarios de activos, gestión continua de vulnerabilidades, control de parches y protección de la infraestructura.

- **NIST SP 800-193**, que define los principios de resiliencia del firmware, incluyendo protección, detección y recuperación ante fallas o compromisos en el nivel de plataforma.

En conjunto, estos marcos aseguran que la gestión de riesgos se realice con un enfoque consistente, alineado a buenas prácticas y aplicable a entornos donde las actualizaciones críticas de firmware representan un elemento central de seguridad.

4. Roles definidos para la Política de Gestión de Riesgos

Autorizing Official / Senior Accountable Official for Risk Management
Responsable de aprobar decisiones de riesgo, aceptar riesgos residuales y validar las acciones propuestas para mitigarlos. Supervisa el cumplimiento de esta política y tiene autoridad final sobre la priorización de riesgos y la asignación de recursos.

Risk Executive (Function)
Coordina la gestión del riesgo a nivel organizacional y asegura que las decisiones se encuentren alineadas con los objetivos estratégicos. Evalúa el impacto acumulado de los riesgos y proporciona lineamientos para la toma de decisiones.

Chief Information Officer (CIO)
Garantiza que la gestión del riesgo esté integrada en la estrategia tecnológica de la organización. Facilita los recursos necesarios para ejecutar las actividades de evaluación y tratamiento del riesgo.

Senior Agency Information Security Officer
Supervisa la implementación de los controles de seguridad relacionados con la gestión del riesgo. Define criterios técnicos de evaluación, valida la aplicación de actualizaciones críticas y coordina acciones con el equipo de seguridad.

Information Owner / Steward
Responsable del riesgo inherente a los datos bajo su custodia. Evalúa el impacto de las vulnerabilidades sobre la información y participa en la priorización de las medidas de mitigación.

System Owner
Responsable del funcionamiento general del sistema. Identifica riesgos operativos, coordina la aplicación de parches y actualizaciones críticas, y asegura que los controles definidos se ejecuten correctamente.

System Security or Privacy Officer
Monitorea la postura de seguridad del sistema, valida vulnerabilidades identificadas, revisa alertas derivadas de firmware y confirma que el tratamiento del riesgo cumpla con las políticas definidas.

System Administrator
Realiza las acciones operativas necesarias para mitigar riesgos, incluyendo aplicar actualizaciones críticas, ejecutar procedimientos de remediación y mantener la integridad de los registros y configuraciones.

Security or Privacy Architect
Diseña y revisa la arquitectura de seguridad para garantizar que incluya controles que reduzcan el riesgo asociado a vulnerabilidades del sistema, incluyendo aquellas relacionadas con firmware.

Common Control Provider
Gestiona controles de seguridad compartidos entre distintos sistemas y asegura que su nivel de madurez sea suficiente para soportar el proceso de gestión de riesgos.

Control Assessor
Evalúa los controles implementados, determina su eficacia y documenta las brechas que puedan incrementar el riesgo.

Enterprise Architect
Asegura que la gestión del riesgo esté integrada en el diseño global de las plataformas tecnológicas, incluyendo dependencias críticas de hardware y firmware.

Mission or Business Owner
Determina el impacto operativo de los riesgos detectados y participa en decisiones de tratamiento que puedan afectar procesos de negocio.

Data Controller / Data Processor
Gestionan el riesgo asociado al procesamiento y uso de datos, asegurando que las actividades cumplan con las obligaciones regulatorias y contractuales.

System User
Cumple con las prácticas establecidas en esta política y reporta de inmediato cualquier comportamiento anómalo que pueda indicar un riesgo emergente.

5. Metodología de Evaluación de Riesgo

La organización emplea una metodología estructurada para la identificación, análisis y evaluación de riesgos que puedan afectar la confidencialidad, integridad y disponibilidad de los sistemas. Esta metodología se basa en principios establecidos por NIST SP 800-30, NIST SP 800-40r4, ISO 27002 y los controles de CIS, y se aplica de forma uniforme a todos los activos incluidos en el inventario corporativo.

El proceso inicia con la identificación de amenazas relevantes para cada activo, incluyendo vulnerabilidades de firmware, la ausencia de actualizaciones críticas, errores de configuración, exposición a actores externos y cualquier debilidad que pueda comprometer la operación. Posteriormente se identifican las vulnerabilidades asociadas, tomando como referencia reportes de fabricantes, avisos de seguridad, boletines de CISA, bases de CVE y mecanismos internos de monitoreo.

Una vez identificadas las amenazas y vulnerabilidades, el riesgo se determina mediante el análisis conjunto de dos factores: la probabilidad de que el evento ocurra y el impacto que tendría sobre la organización. La probabilidad se estima con base en la exposición del activo, su criticidad operativa, la disponibilidad de exploits conocidos y la presencia o ausencia de controles preventivos como parches, mecanismos de verificación de firmware o configuraciones de seguridad. El impacto se evalúa considerando la afectación potencial al negocio, la interrupción de servicios, la pérdida de datos, el daño reputacional y la capacidad de recuperación.

El nivel de riesgo se clasifica en las categorías de Bajo, Medio, Alto o Crítico, y esta clasificación sirve como criterio para priorizar acciones. Los riesgos críticos y altos requieren tratamiento inmediato, especialmente aquellos relacionados con vulnerabilidades de firmware o parches catalogados como actualizaciones críticas por el fabricante o por organismos reguladores. Los riesgos medios y bajos se gestionan conforme a los planes establecidos y se revisan periódicamente.

Finalmente, el tratamiento del riesgo se determina seleccionando una de las opciones reconocidas: mitigar, transferir, aceptar o evitar. La decisión debe quedar documentada, alineada a las responsabilidades definidas en la matriz RACI y aprobada por los roles correspondientes según la gobernanza establecida. El riesgo residual se evalúa y se revisa en ciclos continuos para asegurar que se mantienen los niveles aceptables de seguridad en la infraestructura.

6. Clasificación del Riesgo

La clasificación del riesgo se establece como un mecanismo para determinar la prioridad y el nivel de atención que debe asignarse a cada situación identificada. El nivel de riesgo se asigna considerando la combinación de cuatro elementos: la amenaza identificada, la vulnerabilidad asociada, el impacto potencial sobre los servicios de la organización y la probabilidad de ocurrencia. La clasificación resultante se utiliza para orientar las decisiones de tratamiento y definir tiempos de respuesta.

Los niveles de clasificación empleados por la organización son los siguientes:

Riesgo Bajo: eventos que representan una afectación mínima y no comprometen la continuidad operativa.
Riesgo Medio: eventos que pueden degradar servicios no críticos o generar interrupciones parciales.
Riesgo Alto: situaciones que afectan servicios esenciales, exponen datos sensibles o requieren intervención prioritaria.
Riesgo Crítico: eventos con capacidad de comprometer la integridad del entorno tecnológico, interrumpir operaciones fundamentales o generar un impacto material inmediato.

7. Revisión y mejora continua

La política de gestión de riesgos deberá revisarse de manera periódica para asegurar que su contenido permanezca alineado con las necesidades operativas, regulatorias y de seguridad de la organización. Esta revisión deberá realizarse al menos una vez por año, o de forma inmediata cuando ocurra un incidente crítico que ponga en evidencia fallas en la identificación, evaluación o tratamiento de riesgos.

Como parte de este proceso, se evaluará la efectividad de los controles implementados, la adecuación de los criterios de clasificación y severidad, la actualización de los marcos de referencia utilizados y el ajuste de roles o responsabilidades cuando sea necesario. Cualquier cambio identificado deberá ser documentado formalmente y comunicado a las áreas responsables, asegurando que el proceso de gestión de riesgos se mantenga vigente, coherente y aplicable en escenarios actuales y emergentes, incluyendo aquellos relacionados con vulnerabilidades de firmware y la aplicación de actualizaciones críticas.